

Functional Spec: Password Reset Flow (v3)

1. A user who has forgotten their password clicks 'Forgot password?' on the login screen and is taken to a page where they enter their registered email address and submit it.
2. Upon submission, the system sends a reset link to that email address if an account with it exists, and shows the same generic 'If that email is registered, a reset link has been sent' message regardless of whether the account exists, to avoid revealing which emails are registered.
3. Clicking the reset link within 30 minutes of it being sent takes the user to a page where they can enter and confirm a new password. After 30 minutes, the link must show an 'expired' page instead and must not allow a password change.
4. After successfully setting a new password via the reset link, all of that user's existing login sessions on other devices must be invalidated, requiring them to log in again everywhere.
5. This document was last reviewed by the security team on 2026-02-14 and supersedes the v2 spec dated 2025-11-03.